

PROJECT DOCUMENTATION

**BookWagon: A Secure Web-Based
Platform for Sustainable Book Rental
and Resale**

Prepared by:

Abdillah, Alfaidz

Arig, Reynald

Larroza, Jude Kristian

Submitted to:

Illuminado Canoy

Information Assurance and Security 2

September 2026

1. Project Title

BookWagon: A Secure Web-Based Platform for Sustainable Book Rental and Resale

2. Introduction

BookWagon is a secure web-based peer-to-peer (P2P) platform designed to support the rental and resale of physical books. It provides a centralized platform where students, teachers, readers, bookstores, and book owners can access, share, and circulate books in an affordable and sustainable way.

The system addresses the problem of books becoming unused after their owners no longer need them. Through BookWagon, users can list books for sale or rental, browse available books, place orders, and manage their profiles. This promotes the reuse of physical books while helping users obtain learning and reading materials at lower costs.

Security is a critical part of BookWagon because the system handles user accounts, personal information, passwords, book listings, and transaction-related data. The system therefore incorporates security measures appropriate for a PHP and MySQL/MariaDB environment, including user authentication, Google reCAPTCHA, two-factor authentication (2FA), brute-force protection, secure password hashing, role-based access control, authorization, input validation, prepared statements, session management, data protection, secure file uploads, error handling, and audit logging.

BookWagon also supports Sustainable Development Goal 4 (Quality Education) by improving access to affordable learning materials and Sustainable Development Goal 12 (Responsible Consumption and Production) by encouraging the reuse and circulation of physical books.

3. Problem Statement

The buying, selling, rental, and exchange of secondhand books are often conducted through informal platforms such as social media groups and messaging applications. Although these platforms provide convenient communication, they may lack dedicated security controls, structured transaction management, and reliable activity monitoring.

BookWagon aims to address the following problems:

1. **High Cost of Educational and Reading Materials**

New textbooks and reference materials can be expensive, making them difficult to obtain for students and budget-conscious readers.

2. **Underutilization of Existing Books**

Many books remain unused in homes, classrooms, and personal collections after their owners no longer need them.

3. **Lack of a Centralized Book Circulation Platform**

Users may need to search through different informal platforms to find books available for rental, resale, or exchange.

4. **Security Risks in Informal Peer-to-Peer Transactions**

Informal transactions may expose users to fake accounts, fraudulent listings, unauthorized access, spam registrations, credential attacks, and misuse of personal information.

5. **Lack of Proper Access Control and Accountability**

Without appropriate authorization and activity monitoring, unauthorized users may attempt to access restricted functions, modify protected information, or perform actions outside their assigned permissions.

6. **Insufficient Protection of User-Submitted Information**

Book images, profile information, listings, and other submitted data require proper validation and protection to prevent unauthorized access or malicious uploads.

BookWagon addresses these problems by providing a centralized web-based platform for physical book rental and resale while applying fundamental Information Assurance and Security principles throughout the system.

4. Objectives

General Objective

To design, develop, and implement a secure web-based platform for physical book rental and resale that provides affordable access to books while protecting user accounts, system information, and transactions through appropriate Information Assurance and Security controls.

Specific Objectives

The project aims to:

1. Implement user authentication through secure registration, login, and logout functionality.
2. Implement password protection using bcrypt hashing.
3. Implement Two-Factor Authentication (2FA) through Email-based One-Time Passwords (OTP) using PHPMailer.
4. Implement brute-force protection through temporary account lockout after three consecutive failed login attempts.
5. Implement Google reCAPTCHA during appropriate registration and authentication processes.
6. Implement Role-Based Access Control (RBAC) for administrators, verified sellers, registered users, and guests.
7. Implement authorization and access control for restricted pages, functions, and resources.
8. Implement input validation for user-submitted information.
9. Implement SQL injection prevention through prepared statements.

10. Implement secure PHP session management.
11. Implement data protection according to authentication status, role, and ownership.
12. Implement secure file-upload controls for user-submitted images.
13. Implement dual-party verification (QR code scanning and condition image uploads) to ensure non-repudiation and accountability during physical book handovers and returns.
14. Implement a secure escrow mechanism for rental security deposits to protect users from fraudulent damage claims and lost items.
15. Implement secure error handling without exposing sensitive technical information.
16. Implement an audit trail for important system and security activities.
17. Demonstrate the effectiveness of the implemented security controls through functional security testing.

5. Scope and Limitations

Scope

BookWagon includes:

- User registration and authentication
- Password protection
- Two-factor authentication
- Google reCAPTCHA
- Brute-force protection
- Role-Based Access Control
- Authorization and access control
- Input validation
- Secure database operations
- PHP session management
- Secure file uploads
- Audit logging
- Error handling
- Book browsing and searching
- Book rental and purchase
- Seller management
- User profiles
- Administrative management
- Dual-party QR code transaction verification
- Transaction feedback and rating system
- Proof of delivery photographic uploads for sellers

Future Development:

- Book Swap/Exchange — A feature that will allow users to propose and manage exchanges of physical books with other users. This feature is not included in the current implementation.

Limitations

1. No full online payment gateway is included. Payments are handled through the system's payment verification process rather than direct integration with an online payment provider.
2. Real-time GPS delivery tracking is not provided.
3. Book condition and authenticity depend on seller-provided information.
4. Google reCAPTCHA and authenticator applications depend on third-party services.
5. The initial implementation operates in a local XAMPP environment.
6. The initial deployment is intended for a pilot implementation in Davao City.
7. Delivery arrangements may depend on third-party delivery services or agreements between buyers and sellers.
8. CSRF token protection is identified as a planned security enhancement. The current system mitigates session-based attacks through strict server-side session validation, role-based access control, and Email OTP Two-Factor Authentication, which requires active user participation for all sensitive actions.

6. Target Users

Administrator

Manages users, roles, seller verification, administrative functions, and audit logs.

Verified Seller

Manages authorized book listings, inventory, and order fulfillment.

Registered User

Browses, rents, purchases, and exchanges books while managing their account.

Guest

Browses public listings and accesses registration and login functions without accessing protected features.

7. System Features

Administrator

- Secure administrator login
- User and role management
- Seller application and verification management
- Book listing approval
- Payment, rental, damage dispute, penalty mediation, and refund management

- Audit and security log monitoring
- Account suspension and access control

Verified Seller

- Seller dashboard
- Book listing and inventory management
- Secure book image uploads
- Order and rental management
- Physical handover verification via dual-QR code scanning
- Proof of delivery and handover photo uploads
- Earnings and payout management
- Seller profile, business, and store information management

Registered User

- Secure registration and login with two-factor authentication
- Profile and account settings management
- Book browsing and searching
- Shopping cart and checkout
- Book rental and purchase
- Order and rental tracking and history
- Physical handover verification via QR code scanning
- Pre-acceptance condition remarks and agreement
- Seller application
- Messaging and notifications
- Payment and payout information management

Guest

- Browse public book listings
- Search and view book information
- Access registration and login

8. Security Implementation Plan

BookWagon implements security controls throughout the application to protect user accounts, personal information, book listings, transactions, and administrative functions.

The system uses Vanilla PHP, MySQL/MariaDB through XAMPP, PHP Sessions, prepared statements, password hashing, Google reCAPTCHA, and Two-Factor Authentication.

No.	Security Feature	Implementation Plan
1	User Authentication	Users provide their registered email and password. Credentials are verified server-side before access is granted. Users may also authenticate through Google OAuth 2.0.
2	User Registration	Registration information is validated before an account is created. Google reCAPTCHA is used to help prevent automated registrations.
3	Email Verification	A verification link is sent to the user's registered email address after registration. The account must be verified before access is granted.
4	Password Security	Passwords are securely hashed using PHP's password_hash() with bcrypt and verified using password_verify(). Plain-text passwords are not stored.
5	Two-Factor Authentication (2FA)	Email-based OTP verification provides an additional authentication layer. A 6-digit OTP is generated and sent to the user's registered email address using PHPMailer before login is completed.
6	Brute-Force Protection	Accounts are temporarily locked after three consecutive failed login attempts to help prevent repeated unauthorized access attempts.
7	Google reCAPTCHA	Google reCAPTCHA is used on applicable forms to help prevent automated and malicious requests. The reCAPTCHA response is validated by the server.
8	Google OAuth 2.0	Users may sign in using their Google Account. Google verifies the user's identity before the system grants access.
9	Role-Based Access Control (RBAC)	Administrator, Verified Seller, Registered User, and Guest roles are separated. Each role is granted access according to its permitted functions.
10	Authorization	Server-side checks determine whether an authenticated user has permission to perform a requested action or access a protected resource.

11	Access Control	Protected pages and functions require appropriate authentication and permissions. Access is restricted based on the user's role and ownership of applicable resources.
12	Input Validation	User-submitted information, including registration, book listings, and checkout data, is validated before processing or storage.
13	SQL Injection Prevention	Database operations use prepared statements and parameterized queries. User-supplied values are not directly concatenated into SQL statements.
14	Session Security	PHP sessions maintain authenticated user information. Session data is cleared and the session is destroyed when the user logs out.
15	Audit Logging and Error Handling	Important authentication, administrative, and system activities are recorded for accountability. User-facing errors do not expose sensitive technical information or database details.
16	Non-Repudiation (Dual-Party Verification)	Physical handovers require the Seller to upload photographic proof of delivery, while the Renter/Buyer must digitally sign the transaction via QR Code scanning and submit a pre-acceptance condition acknowledgment. This dual-layered verification prevents false claims of non-delivery or pre-existing damage.
17	Wallet and Transaction Security	Wallet balances, security deposits, refunds, and withdrawal requests are processed exclusively through authorized server-side transactions. Balance modifications require appropriate transaction conditions and, where applicable, administrator approval. Users cannot directly modify their wallet balance through client-side requests

9. System Architecture

BookWagon follows a multi-tier web application architecture consisting of:

1. Client / Presentation Tier
2. Web Application Tier
3. Authentication and Security Layer
4. Database Tier

The architecture separates the user interface, application processing, security mechanisms, and persistent data.

Client / Presentation Tier

Users interact with BookWagon through a standard web browser. The interface provides book browsing, registration, login, profile management, marketplace functions, seller tools, and administrative features. The presentation layer uses HTML, CSS, Bootstrap 5, JavaScript, and jQuery to render dynamic content returned by the PHP application layer.

Web Application Tier

The application runs on Apache HTTP Server through XAMPP, using PHP 8.2 as the primary server-side language. PHP processes all incoming requests and is responsible for user authentication, marketplace operations, seller operations, rental and purchase functions, and administrative activities.

Authentication and Security Layer

This layer contains the security controls used throughout the application, including:

- User Authentication (credential-based and Google OAuth)
- Email Verification (token-based for new registrations)
- Bcrypt password hashing
- Brute-force protection (lockout after 3 failed attempts)
- Google reCAPTCHA (registration)
- Email OTP Two-Factor Authentication
- One-time Recovery Codes
- Role-Based Access Control (Admin, Seller, User, Guest)
- Authorization (server-side role and ownership checks)
- Input validation (client-side and server-side)
- SQL injection prevention (prepared statements)
- Secure file uploads (type, MIME, size validation)
- Session security (secure creation and destruction)
- Audit logging

Database Tier

BookWagon uses MySQL/MariaDB (via XAMPP) with the bookwagon_db database. The database stores all persistent data including user accounts, book listings, orders, rentals, transactions, and audit records.

The database contains information related to:

- Users
- Roles

- Sellers
- Books
- Book images
- Cart
- Orders
- Rentals
- Notifications
- Audit logs

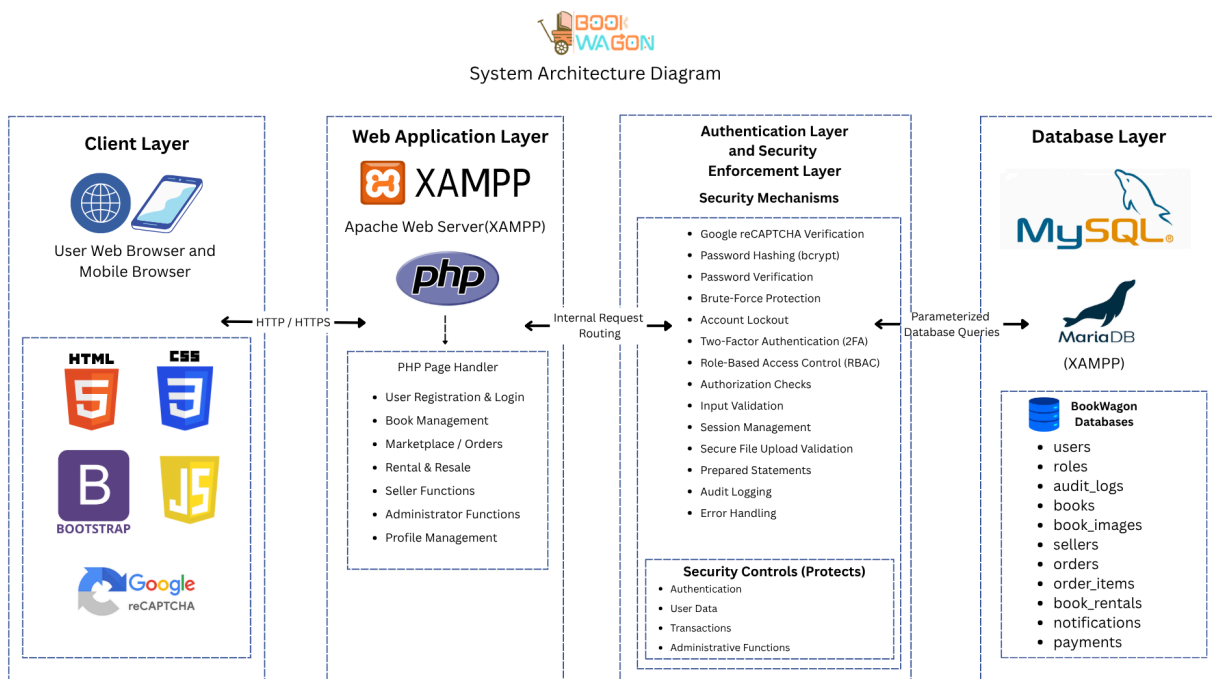


Figure 1. BookWagon System Architecture Diagram

10. Use Case Design

BookWagon has four primary actors:

- Guest
- Registered User
- Verified Seller
- Administrator

Guest

Guests can browse public books, search listings, view public information, access registration, and access secure login.

Registered User

Registered users can manage their profiles, browse books, rent and purchase books, manage their cart and orders, and submit pre-acceptance condition remarks to confirm physical book handovers.

Verified Seller

Verified sellers can manage listings, inventory, book images, rental and selling information, order fulfillment, and upload proof-of-delivery photos during handovers.

Administrator

Administrators manage users, roles, seller verification, manual payment verifications, dispute resolutions, system activities, and audit logs.

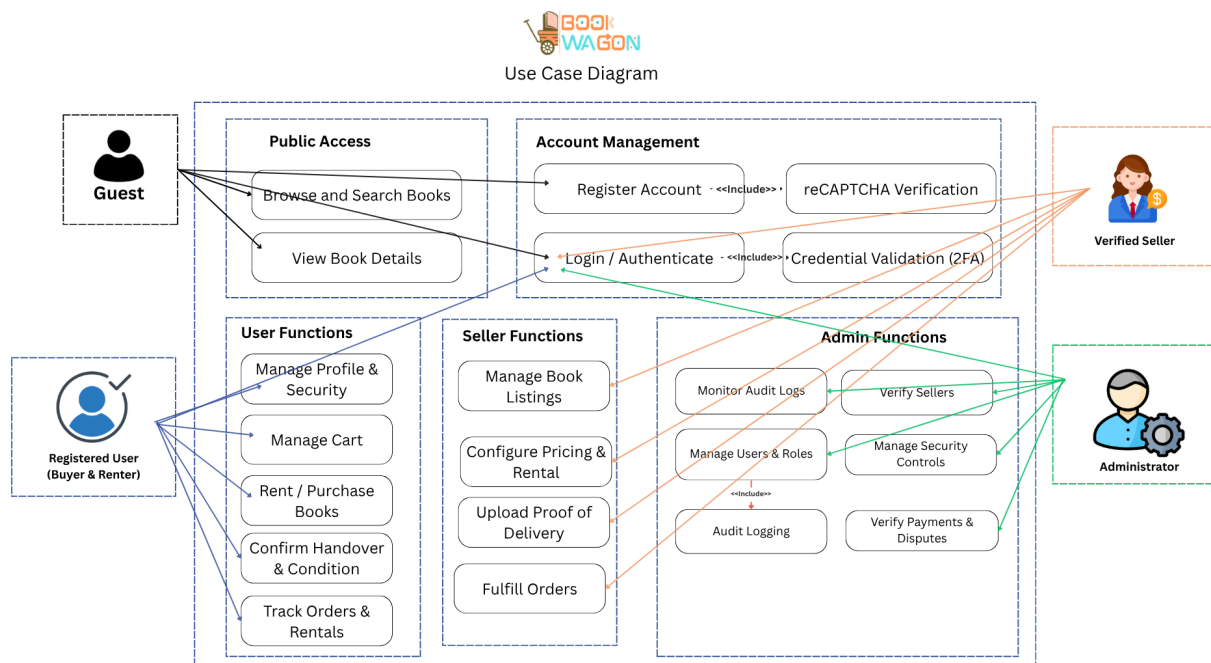


Figure 2. BookWagon Use Case Diagram

Use Case Specification

ID	Use Case	Actor	Security Controls
UC-01	User Registration	Guest	reCAPTCHA, validation, duplicate checking, password hashing
UC-02	Secure Login	User/Seller/Admin	reCAPTCHA, password verification, lockout, 2FA, session security
UC-03	Rental and Purchase	Registered User	Authentication, authorization, validation, prepared statements
UC-04	Listing Management	Verified Seller	RBAC, authorization, validation
UC-05	Book Image Upload	Verified Seller	File validation and access control
UC-06	Physical Handover Verification	User / Seller	Non-repudiation, session verification, file validation, input validation
UC-07	Seller Verification	Administrator	Administrator authorization and audit logging

UC-08	Payment & Dispute Management	Administrator	Administrator authorization, prepared statements, audit logging
UC-09	Audit Monitoring	Administrator	Administrator authorization and protected database access

11. Database Design

The BookWagon database uses MySQL/MariaDB to store information required by the platform. The architecture strictly follows Third Normal Form (3NF) to eliminate data redundancy and ensure data integrity.

Module 1: Security and Identity

- users: Registered user accounts, credentials, role (usertype), 2FA settings, and recovery codes.
- admin: Administrator accounts and login credentials.
- login_history: Records of login attempts including IP address and device information.
- audit_logs: System-wide security and activity event records with timestamps.

Module 2: Sellers and Verification

- sellers: Seller applications, KYC verification status, and business details.
- seller_payouts: Seller payout requests and processing status.
- bank_accounts: Seller linked payout and bank account details.

Module 3: Books and Listings

- books: Book listings including title, author, price, rental price, condition, and approval status.
- book_images: Multiple condition photos uploaded per book listing.
- book_collections: User personal saved book collections.
- user_favorites: Individual favorited books per user.
- delivery_methods: Supported delivery options per listing.

Module 4: Transactions and Financials

- cart: Shopping cart items per user.
- orders: Purchase and rental order records.
- order_items: Individual line items within each order.

Figure 3. BookWagon Database Design ERD

12. System Flowchart

The BookWagon system utilizes multiple process flows to manage platform security and complete the physical lifecycle of transactions.

A. Authentication and Access-Control Flow To ensure platform security, the system's entry process follows these major stages:

1. **Guest Exploration:** Guests can browse public listings but hit a login wall when attempting to interact.
2. **Login Request & Input Validation:** The system sanitizes user input and performs an account lookup.
3. **reCAPTCHA Verification:** Prevents automated bot attacks during entry.
4. **Account Lockout Check:** Temporarily restricts access if brute-force protection is triggered (3 failed attempts).
5. **Password Verification:** The system securely validates the credential against the stored bcrypt hash. (Note: Bypassed if using Google OAuth 2.0).
6. **Two-Factor Authentication:** Requires an Email OTP to verify the user's active identity.
7. **Session Establishment:** Secure PHP session variables are generated for the authenticated user.
8. **Role Authorization:** The system checks the user type and routes the user to the correct dashboard (Admin, Seller, or User).
9. **Audit Logging:** The login event, including device and IP data, is permanently recorded.

B. Core Transaction and Handover Flow Once authenticated, the system manages the primary peer-to-peer e-commerce and rental lifecycle through the following definitive stages:

- **Listing & Verification:** Users apply for verified seller status. The Administrator reviews the KYC documents. Once approved, the seller uploads book inventory, which is subject to a final Administrator Product Approval before being published to the marketplace.
- **Checkout & Payment:** Buyers select "Rent" or "Buy," triggering the creation of order records and the locking of security deposits for rentals. The buyer submits proof of payment, which the Administrator must verify and approve before the order proceeds.
- **Physical Handover (Non-Repudiation):** During the arranged meet-up, the seller uploads a proof-of-delivery photo to the system. The buyer physically inspects the book, submits a pre-acceptance condition remark into the application, and then scans the seller's dynamically generated QR code. This digital signature finalizes the purchase or locks the rental agreement.
- **Return & Resolution:** Upon the rental due date, a final QR scan confirms the physical return of the book. The seller assesses the item's condition. A clean return prompts the system to initiate a full deposit refund. If damaged, the seller uploads photographic proof, and the Administrator arbitrates the dispute to determine the appropriate damage penalty deduction.

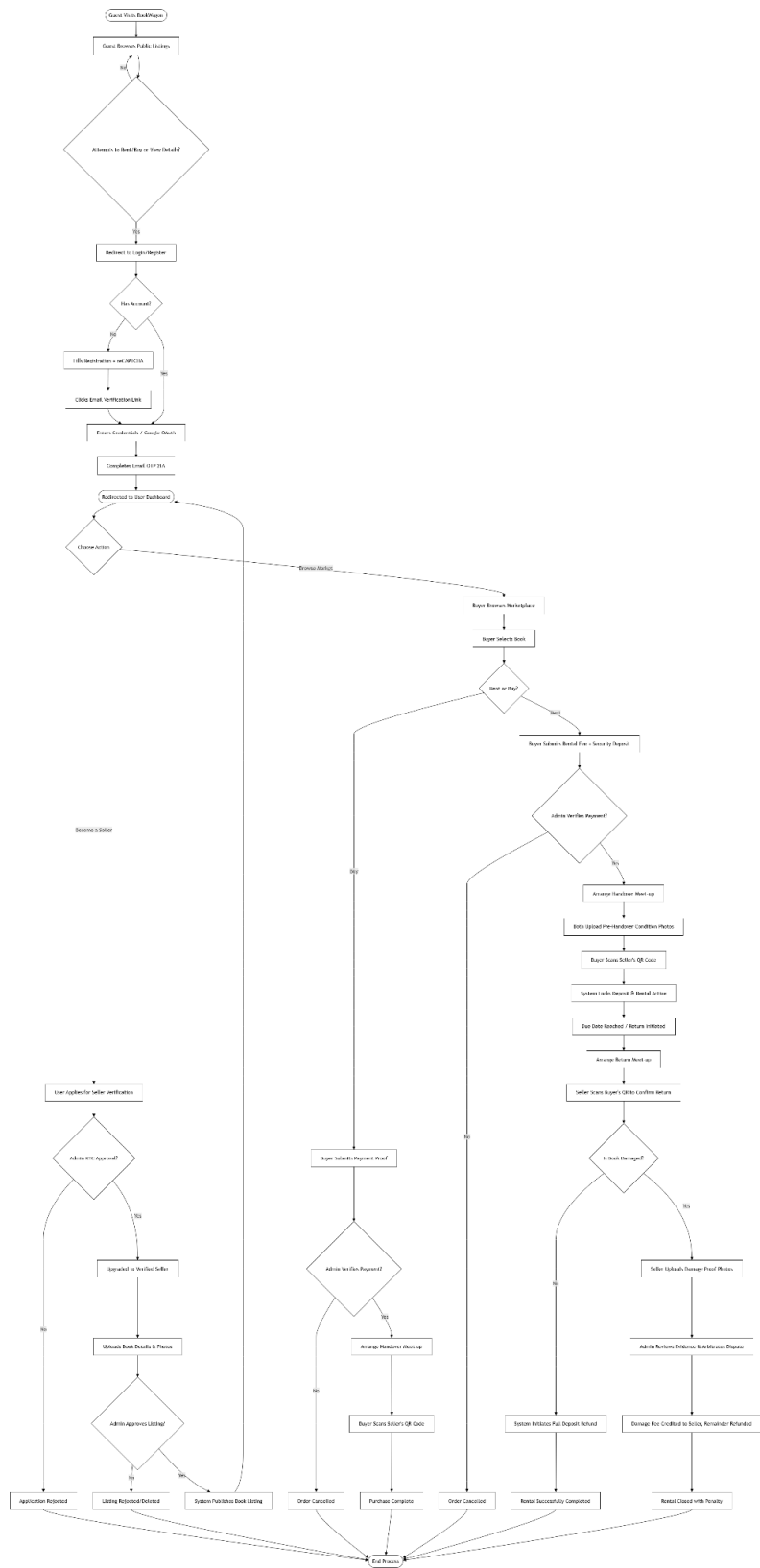


Figure 4. Bookwagon System Flowchart